



DNS security and privacy:

DNS, DNSSEC, DoT, DoH, Oblivious
DoH, DoQ

Kamil Jerabek

Brno University of Technology

Faculty of Information Technology

Networks and Distributed Systems Research Group

Domain Name System (DNS)

Domain Name System

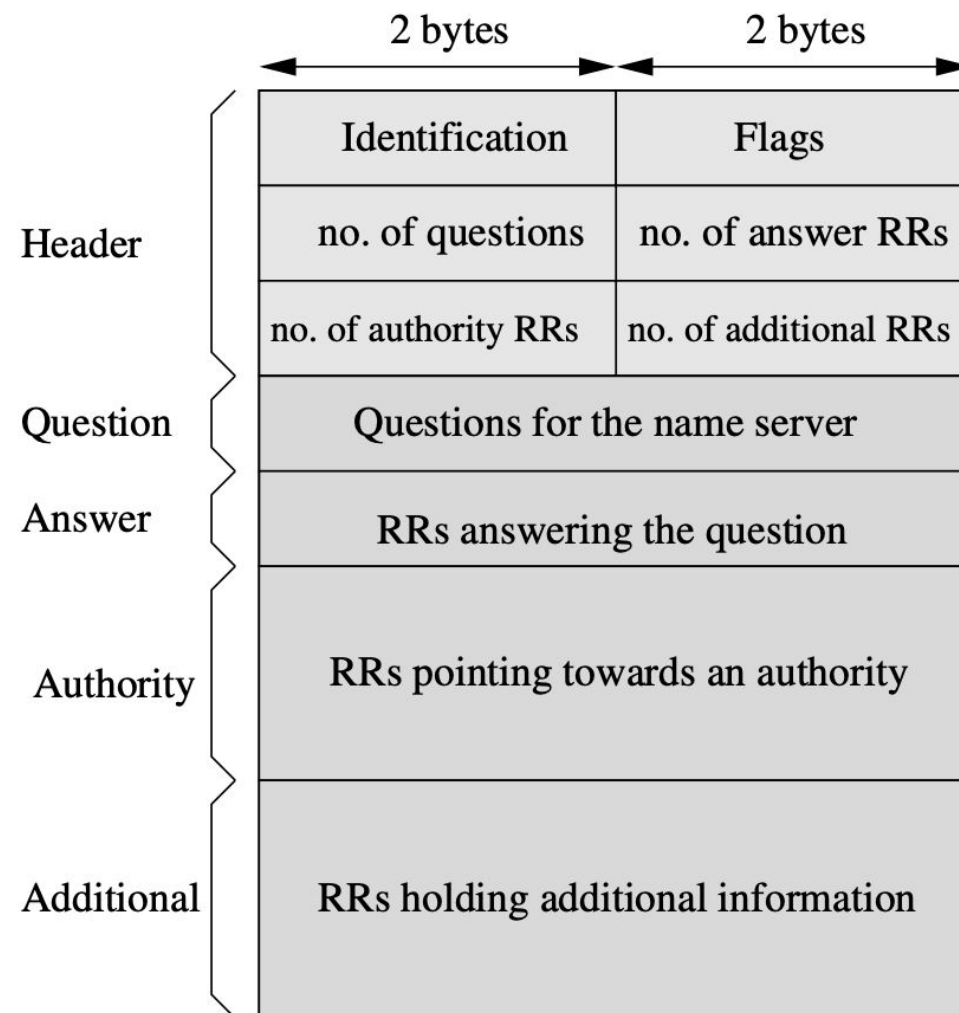
- DNS is global directory of host names and other services
- It provides a system for translation of domain names into IP addresses
- **DNS architecture**
 - Namespace of DNS addresses + mapping of domain names to IP addresses
 - Storage of DNS namespace
 - Data access and lookups
- The domain names are organized in an inverted searching tree

Domain Name System

- Domain names directory is physically stored on DNS servers
 - DNS servers contains information about tree structure
 - Each server manages only portion of domain names - a zone
- Type of servers:
 - **Primary (master, primary name servers)**
 - Contains full authoritative records about managed domains
 - Each domain only one primary server
 - **Secondary (slave, secondary name servers)**
 - Stores authoritative copies from primary servers
 - **Backup (caching-only name servers)**
 - Accept requests and forward to other servers
 - Cache responses
 - Offers non-authoritative responses (can be not actual)

DNS Protocol

- Introduced in RFC 1035
- Both underlying transport protocols UDP and TCP
 - Primarily UDP used
 - Port 53



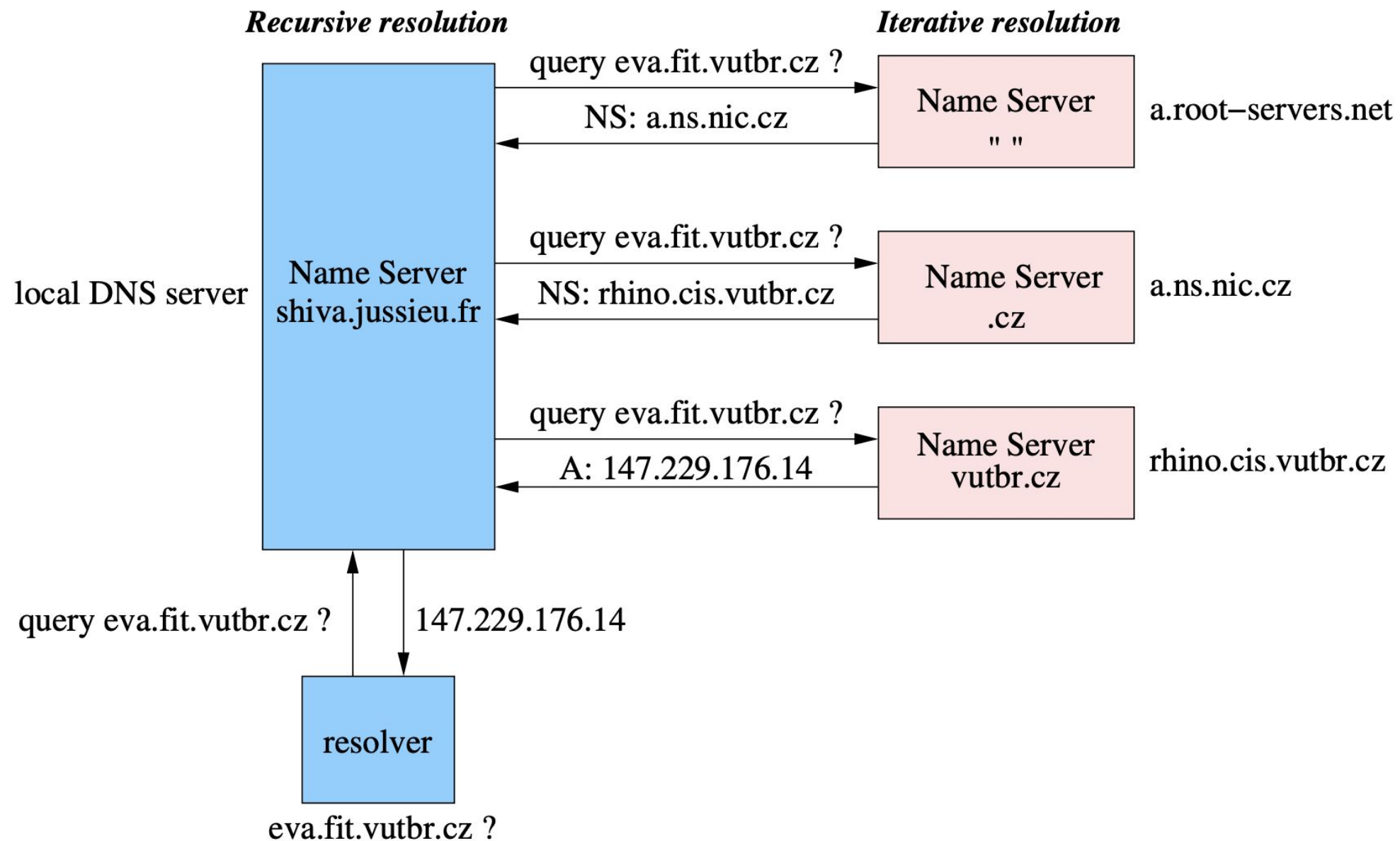
Example: answer to `www.fit.vutbr.cz` query

59058	qr, rd, ra, ad
1	1
4	6
www.fit.vutbr.cz IN A	
www.fit.vutbr.cz 13963 IN A 147.229.9.23	
fit.vutbr.cz. 13869 IN NS guta.fit.vutbr.cz. fit.vutbr.cz. 13869 IN NS kazi.fit.vutbr.cz fit.vutbr.cz 13869 IN NS rhino.cis.vutbr.cz fit.vutbr.cz 13869 IN NS gate.feec.vutbr.cz	
guta.fit.vutbr.cz. 14062 IN A 147.229.8.11 kazi.fit.vutbr.cz. 13869 IN A 147.229.8.12 rhino.cis.futbr.cz. 86211 IN A 147.229.3.10 guta.fit.vutbr.cz. 14156 IN AAAA 2001:67c:1220:809 rhino.cis.vutbr.cz. 43692 IN AAAA 2001:67c:1220:e000:	

DNS Resolution

- Searching records in DNS
- **DNS Resolver**
 - Communication is of type client - server
 - System routine (resolver) resolves domain names for an application
- **DNS Resolution**
 - Process of searching answer for DNS query in DNS system
 - **Recursive Query**
 - If server do not know the answer, it sends the query to other servers
 - **Iterative Query**
 - If server do not know the answer, responds with a link to a server that can have the answer

Types of Resolution



Resource Records

- DNS Resource Records format
- Defined in RFC 1034, RFC 1035

Resource Records Format

Name (variable length)
Type (16 bits)
Class (16 bits)
TTL (32 bits)
RDLENGTH (16 bits)
RDATA (variable length)

Example

www.fit.vutbr.cz
CNAME
IN (0x0001)
4106 (1 h 8 min 26 s)
4
tereza.fit.vutbr.cz

Types of Records

- **A (Address)**
 - Direct mapping of domain name to IPv4 address
- **AAAA**
 - Direct mapping of domain name to IPv6 address
- **SOA (Start Of Authority)**
 - Every zone has only one SOA
 - Contains name of primary server, administrators address, several timers (Refresh, Retry, Expire, Minimum) and Serial identifying change of record
- **NS (Name Server)**
 - Determines authoritative server(s) for a zone
- **CNAME (Canonical Name)**
 - Maps alias to canonical name of a host
 - Alias is e.g. www, email, ...

Types of Records

- **PTR (Domain Name Pointer)**
 - Maps IPv4 and IPv6 address to domain name (reverse mapping)
- **NAPTR (Naming Authority Pointer)**
 - Dynamic configuration
 - Uses regular expressions for dynamic records
- **SRV (Service Record)**
 - Localization of services and servers, XMPP, SIP, ...
- **MX (Mail Exchanger)**
 - Contains mail servers to use for a domain
 - Multiple servers possible
- **TXT**
 - Extends the information about domain, server, administrator, ...

Tools For DNS Resolving

`whois <domain_name|IP>`

- Get the information about the owner of domain or IP address

`host|dig <domain_name>`

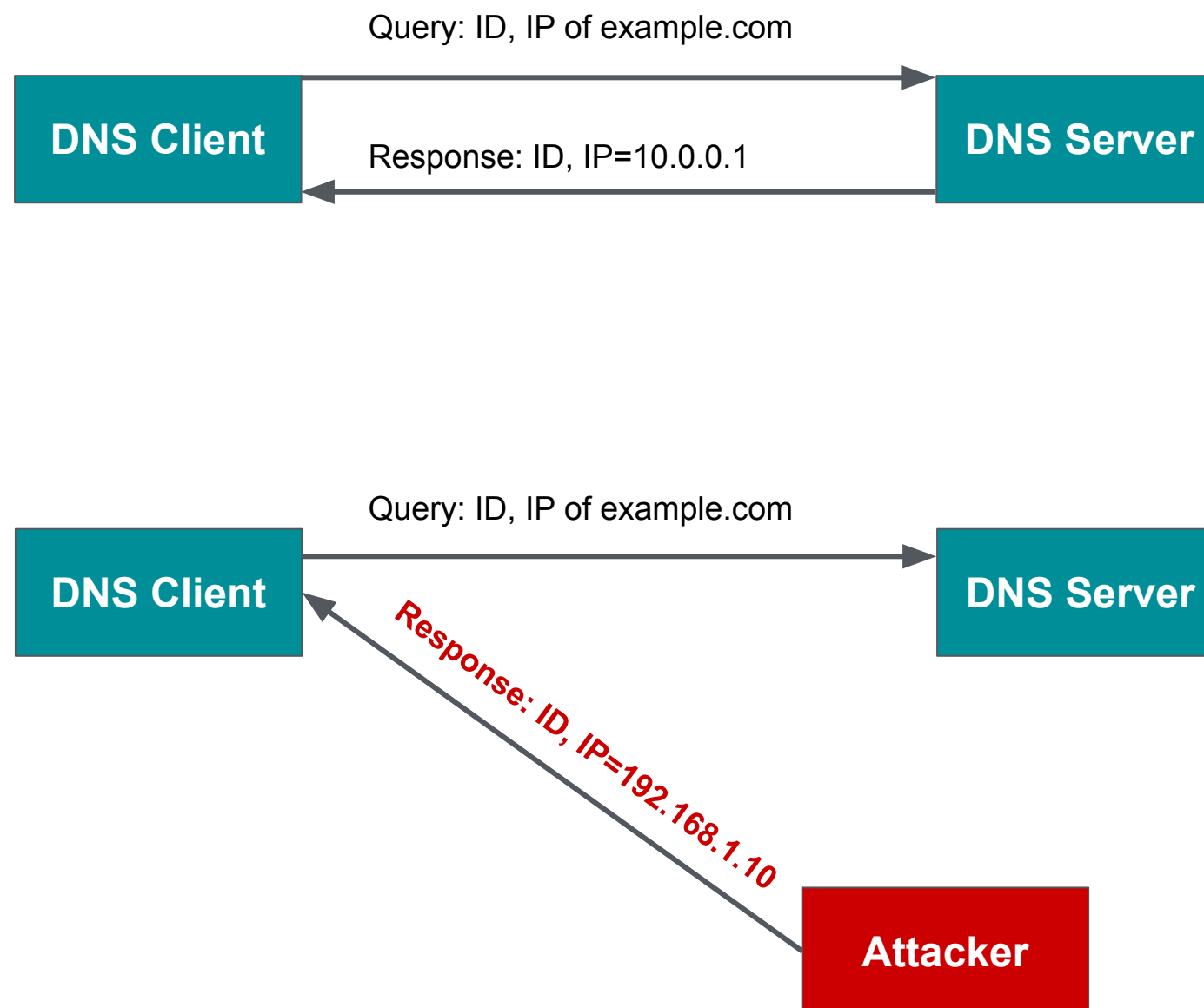
- Do the resolving for given domain name

`nslookup [OPTIONS] <domain_name>`

- OPTIONS
 - `-type=<record_type_shortcut>`
- example: `nslookup -type=AAAA cisco.com`

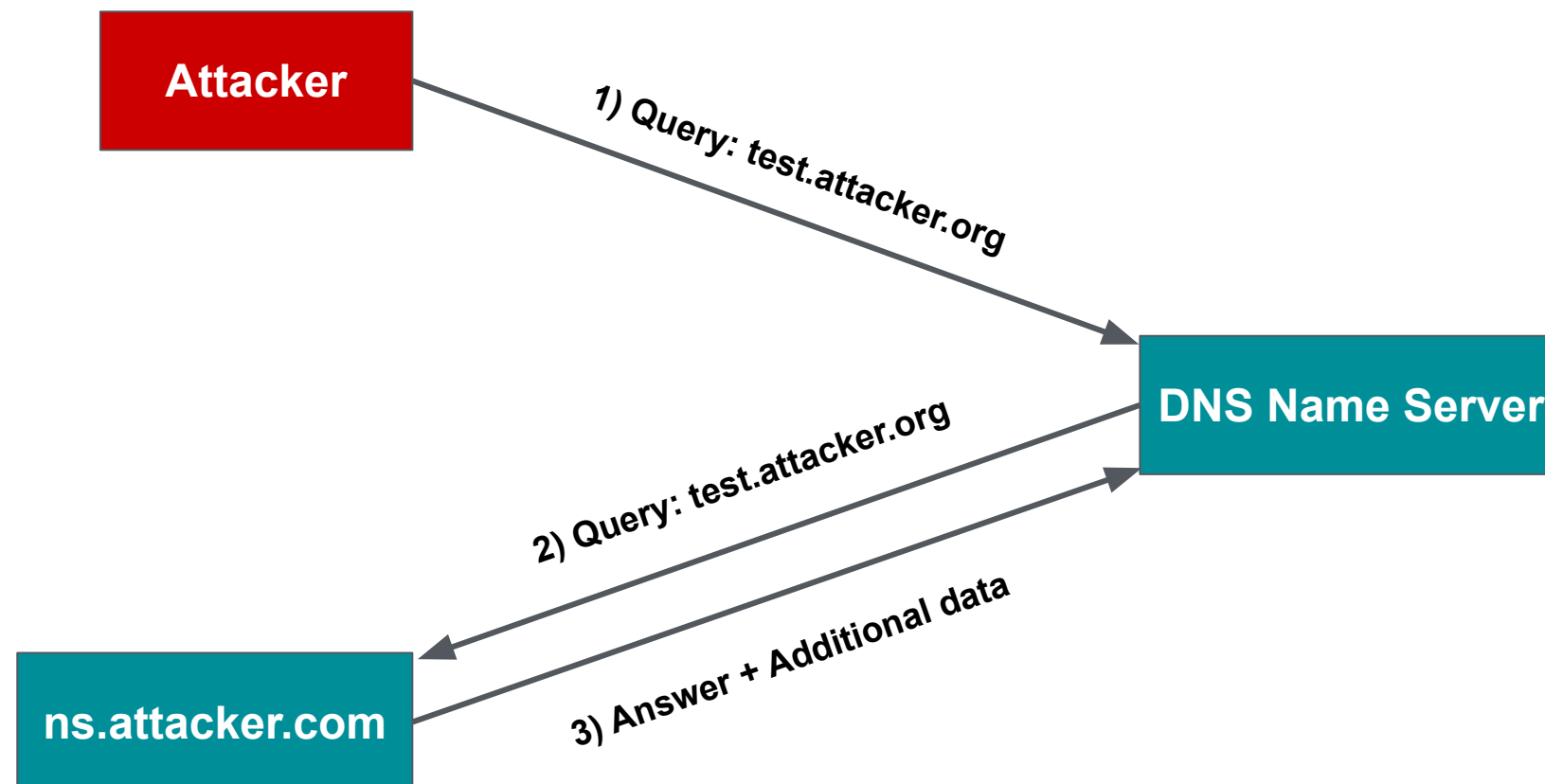
Vulnerabilities 1

- Unauthorized response for client query from the attacker



Vulnerabilities 2

- DNS cache poisoning
- Insertion of incorrect information into cache



Vulnerabilities 3

- Distributed Denial of Service (DDoS)
- DDoS against root servers
- Blocking service for legitimate responses



Vulnerabilities 4

- DNS does not encrypt the traffic
- So anyone who can sniff the traffic can check the content of DNS packets
- This effect is used by network administrators to manage users
 - Point to right servers (in companies)
 - Or to filter the traffic
- But ISPs can also monitor (spy) the traffic
- Privacy issue

DNS Security Extension (DNSSEC)

DNSSEC

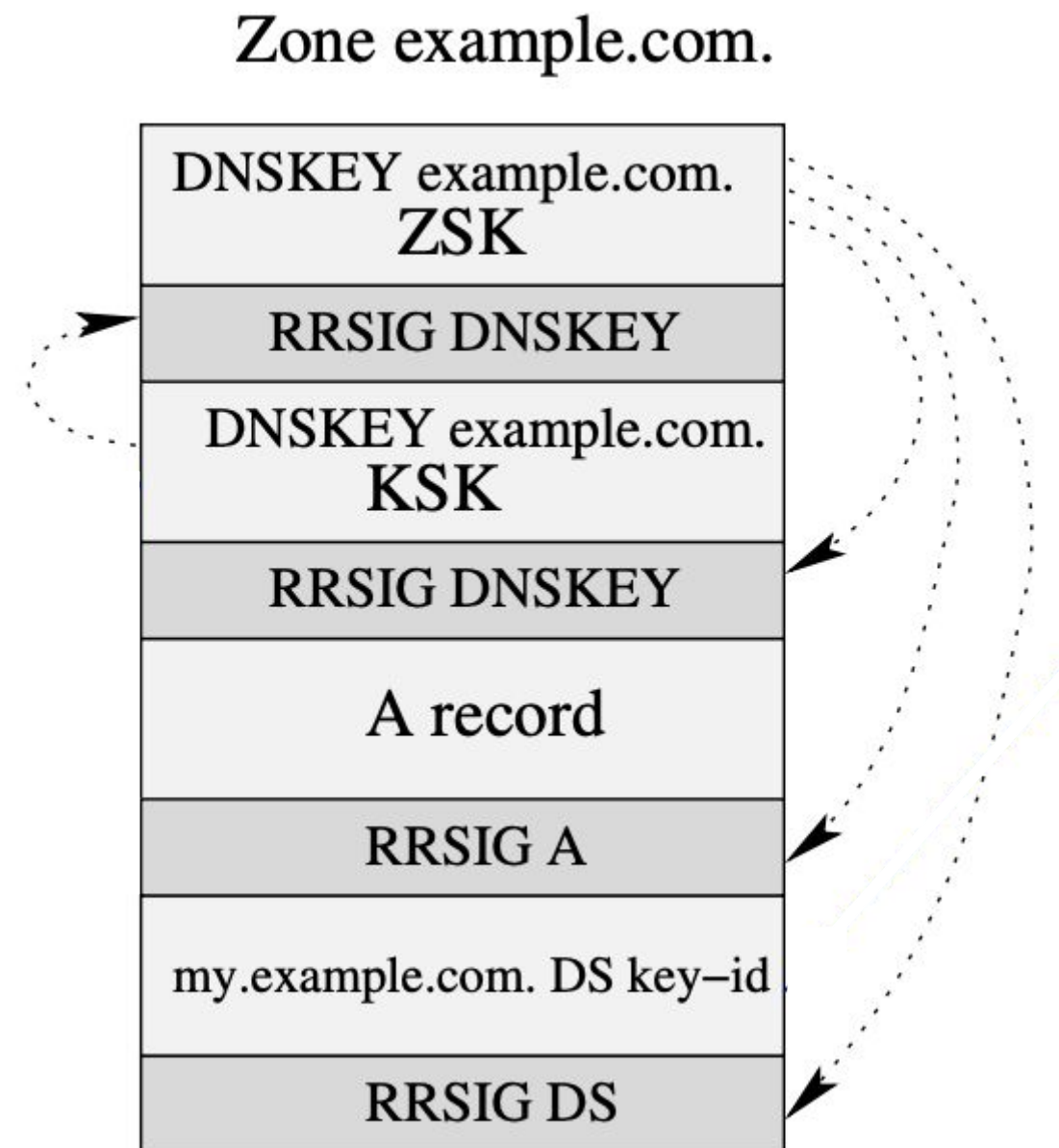
- Covered by RFC 4033, RFC 4034, RFC 4035, RFC 5155
- Adds integrity and authentication to DNS data
- Asymmetric cryptography used for DNS record signing
- **Zone Signing Key (ZSK)**
 - Public, private key
 - Used for signing DNS records in zones
- **Key Signing Key (KSK)**
 - Public, private key
 - Used for signing keys that are used for signing records

DNSSEC Records

- New records are defined for DNSSEC
- **DNSKEY**
 - Public key for signature verification
- **RRSIG**
 - Signature of the record
- **NSEC, NSEC3**
 - Link to another record when the queried domain does not exists
- **DS**
 - Record for verification of DNSKEY record
 - Stored in superior domain

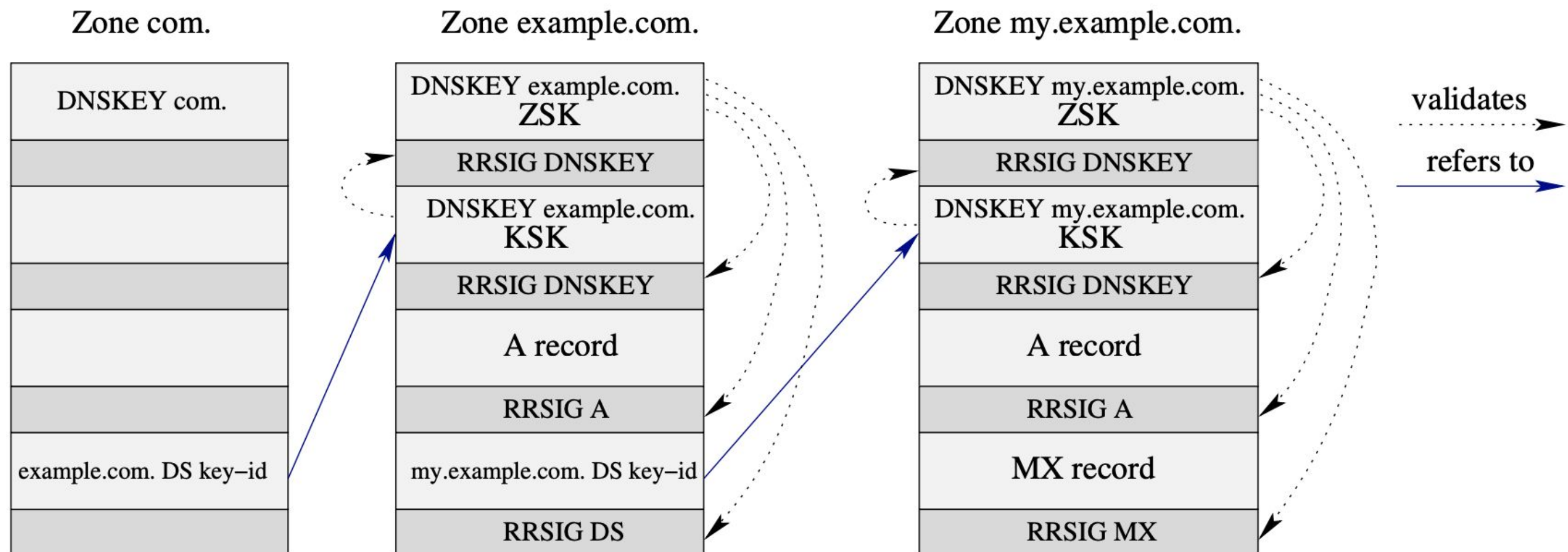
Zone Signing

- **ZSK**
 - **Public Key**
 - Stored in DNSKEY record used to validate signatures in RRSIGs
 - **Private Key**
 - Used to sign zone records signatures stored in RRSIGs
- **KSK**
 - **Public Key**
 - Stored in DS record used to validate DNSKEY
 - **Private Key**
 - Used to sign DNSKEY



Signing Hierarchy

- Chain of trust
- Verification of key authenticity by the superior domain
- Public and Private key pair exists for every zone
- DNSSEC records are significantly increasing packet payload size



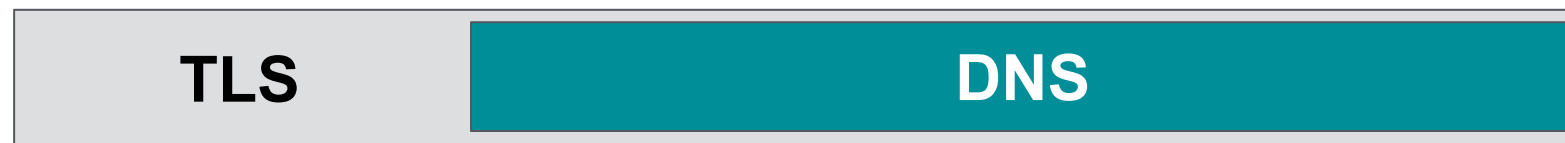
DNSSEC

- **DNSSEC does not provide encryption!**
 - Everyone who will sniff the traffic can read the content of DNS messages
 - DNSSEC provides only integrity and authentication but not encryption
 - It does not solves privacy issues
- **What we can use to encrypt DNS traffic?**
 - There are few attempts to encapsulate DNS messages to other encrypted protocols
 - DNS over TLS
 - DNS over HTTPS
 - DNS over QUIC

DNS over TLS (DoT)

DNS over TLS

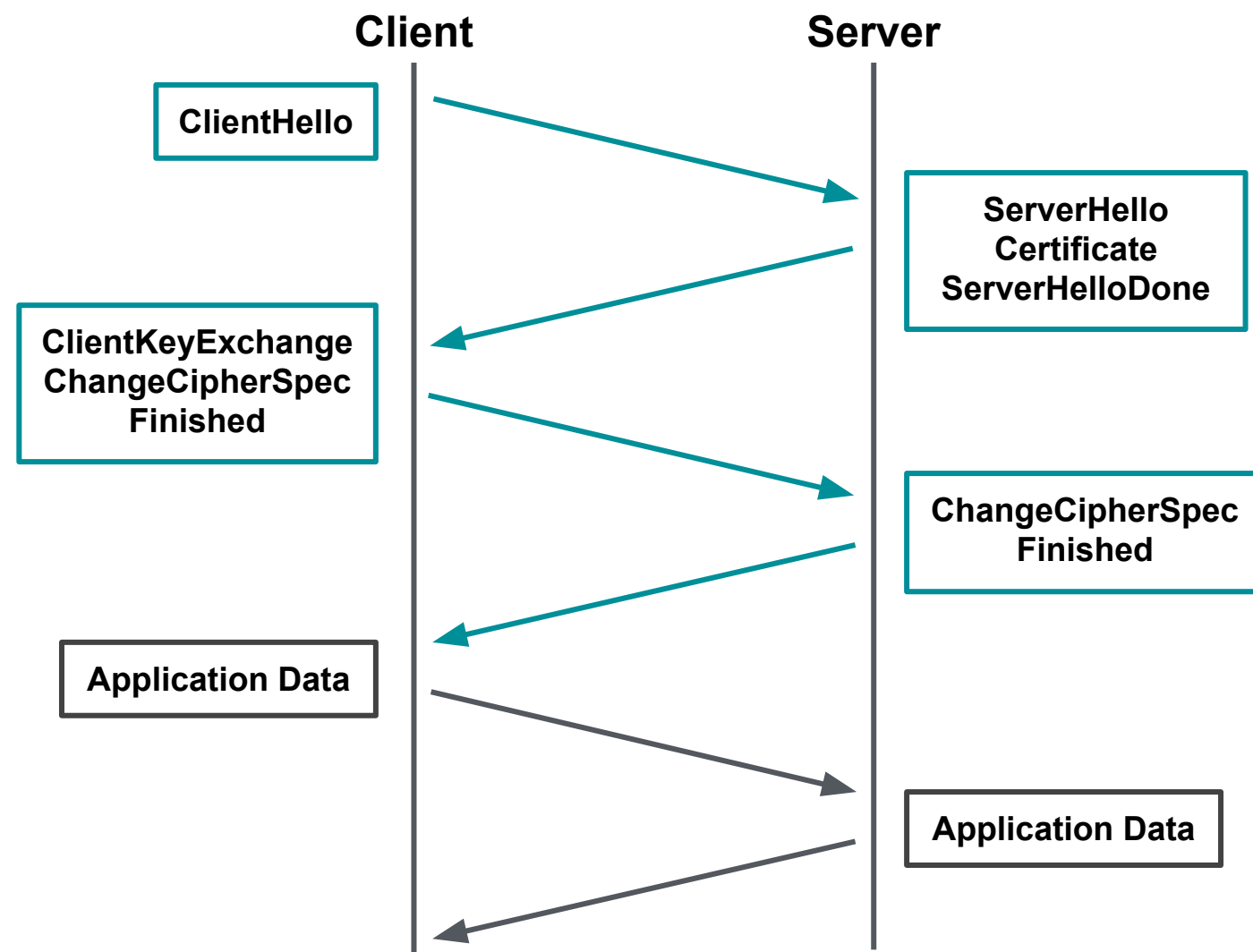
- Standard DNS queries and responses as defined in DNS are encapsulated by TLS protocol
- TLS protocol is used for encryption and transport of DNS messages
- Multiple queries can be transmitted over the same encrypted channel



- Defined in RFC 7858
- **Dedicated port 853/tcp**
- Support on the OS level, proxies and resolvers

Procedure

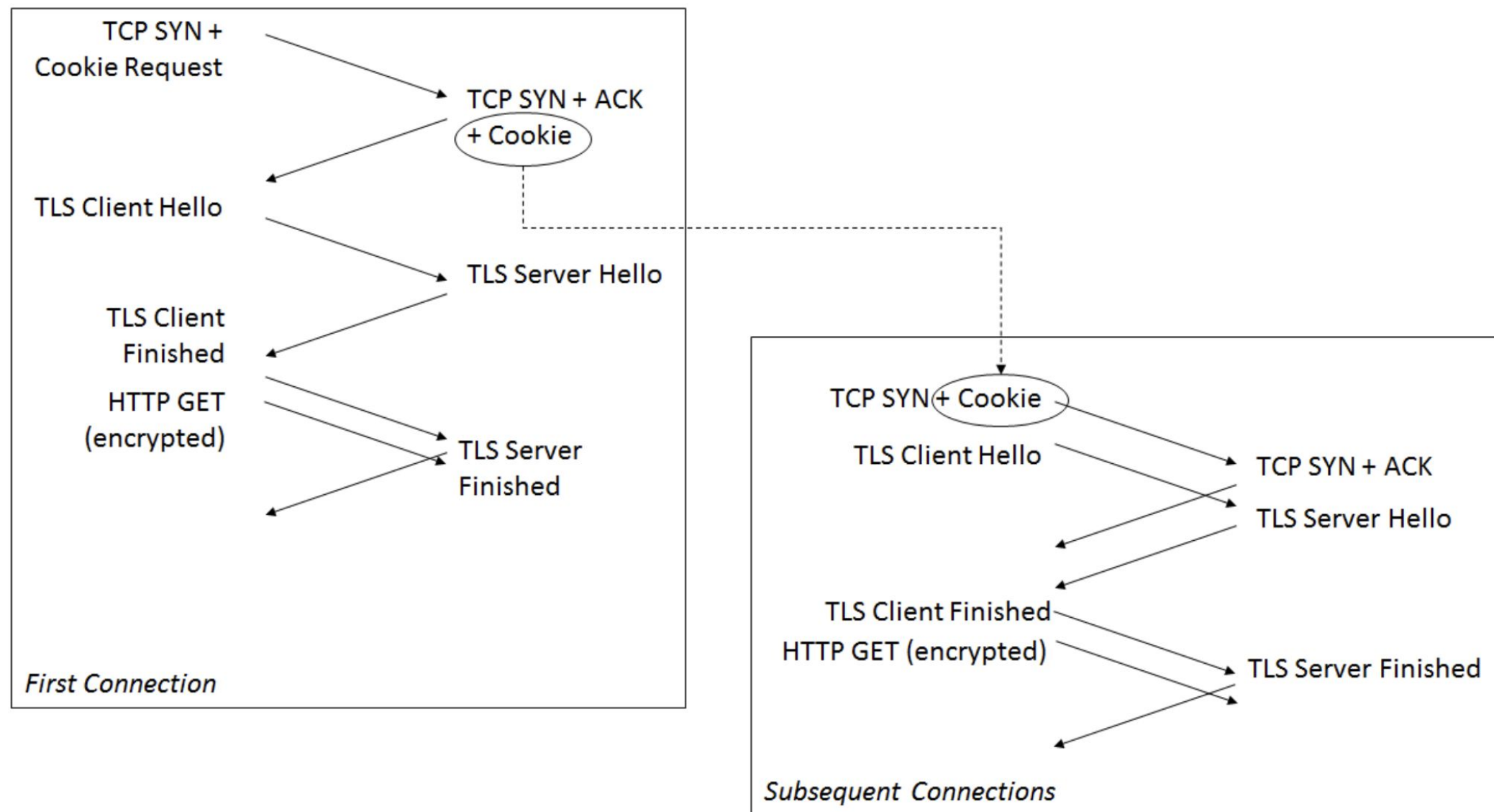
- TCP handshake first
- TLS handshake to establish secure channel
- Standard DNS queries and responses over encrypted channel
- **Connection establishment overhead compared to DNS UDP/TCP**



Overhead Reduction

- 1-RTT

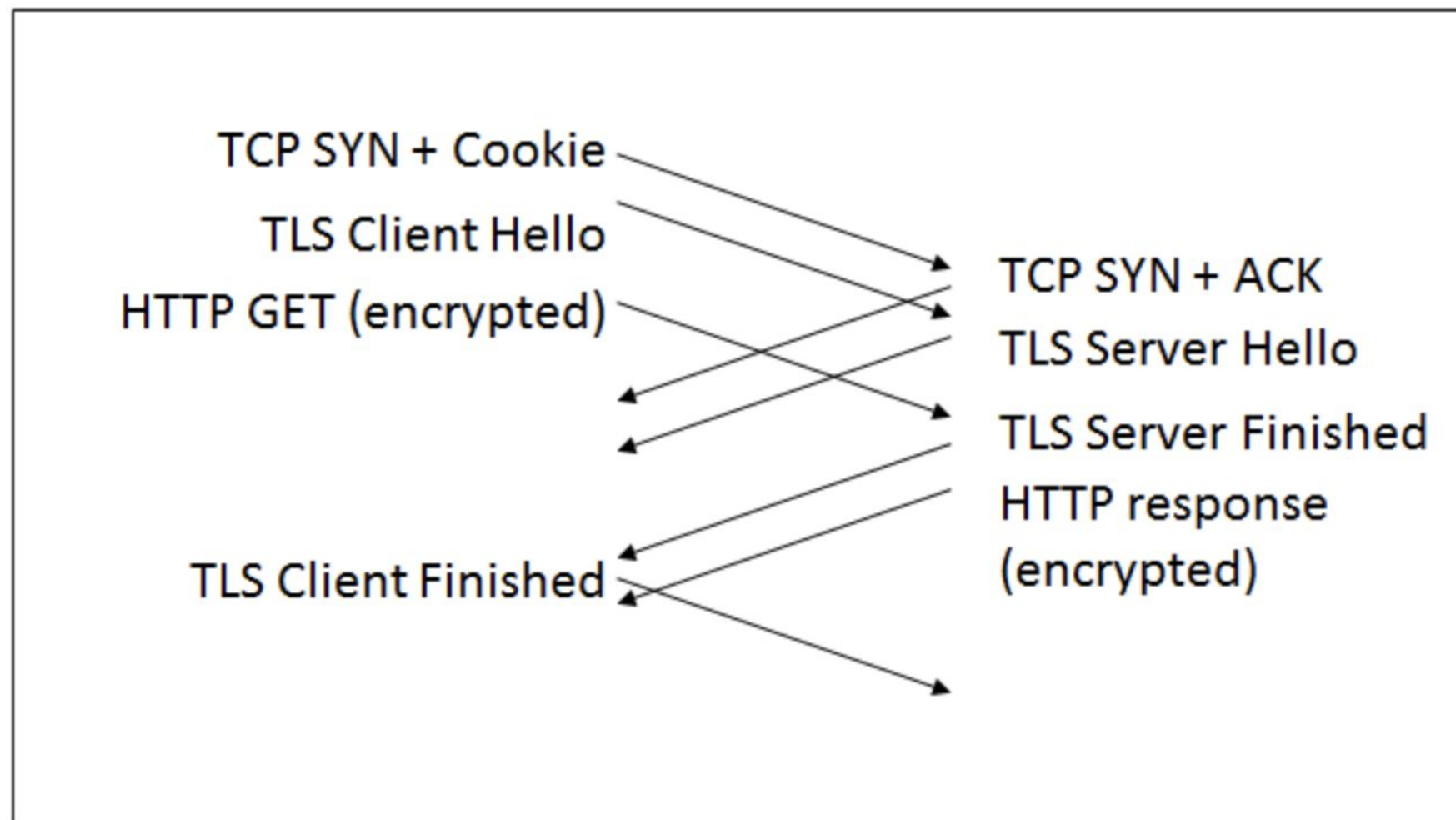
- TLS False Start (RFC 7918) and TCP Fast Open (RFC 7413)



Source: <https://blogs.windows.com/msedgedev/2016/06/15/building-a-faster-and-more-secure-web-with-tcp-fast-open-tls-false-start-and-tls-1-3/>

Overhead Reduction 2

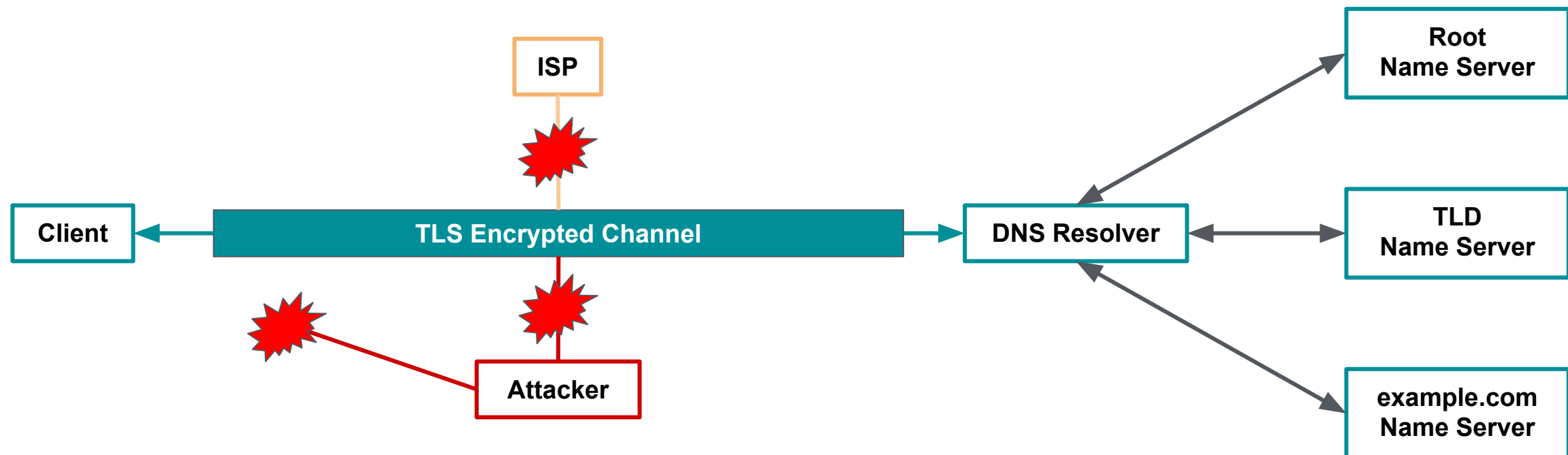
- **0-RTT with TLS 1.3 (RFC 8446)**



Source: <https://blogs.windows.com/msedgedev/2016/06/15/building-a-faster-and-more-secure-web-with-tcp-fast-open-tls-1-3/>

DNS over TLS

- DoT moves the missing privacy to other party
- DNS traffic is encrypted only between Client (browser) and the DNS Resolver



- Can we trust the DNS Resolver provider? Is it really private?
- Are those connections between DNS Resolver and Name Servers secure?

Tools

kdig

```
$ kdig -d @1.1.1.1 +tls-ca +tls-host=cloudflare-dns.com example.com
;; DEBUG: Querying for owner(example.com.), class(1), type(1), server(1.1.1.1), port(853), protocol(TCP)
;; DEBUG: TLS, imported 170 system certificates
;; DEBUG: TLS, received certificate hierarchy:
;; DEBUG:  #1, C=US,ST=CA,L=San Francisco,O=Cloudflare\, Inc.,CN=*.cloudflare-dns.com
;; DEBUG:      SHA-256 PIN: yioEpqeR4WtDwE9YxNVnCEkTxIjx6EEIwFSQW+lJsbC=
;; DEBUG:  #2, C=US,O=DigiCert Inc,CN=DigiCert ECC Secure Server CA
;; DEBUG:      SHA-256 PIN: PZXN3lRAY+8tBKk20x6F7jIlHzr2Yzmqc3JnyfXoCw=
;; DEBUG: TLS, skipping certificate PIN check
;; DEBUG: TLS, The certificate is trusted.
;; TLS session (TLS1.3)-(ECDHE-SECP256R1)-(ECDSA-SECP256R1-SHA256)-(AES-256-GC
;; ->>HEADER<<- opcode: QUERY; status: NOERROR; id: 58548
;; Flags: qr rd ra; QUERY: 1; ANSWER: 1; AUTHORITY: 0; ADDITIONAL: 1

;; EDNS PSEUDOSECTION:
;; Version: 0; flags: ; UDP size: 1536 B; ext-rcode: NOERROR
;; PADDING: 408 B

;; QUESTION SECTION:
;; example.com.                IN  A

;; ANSWER SECTION:
example.com.                2347    IN  A    93.184.216.34

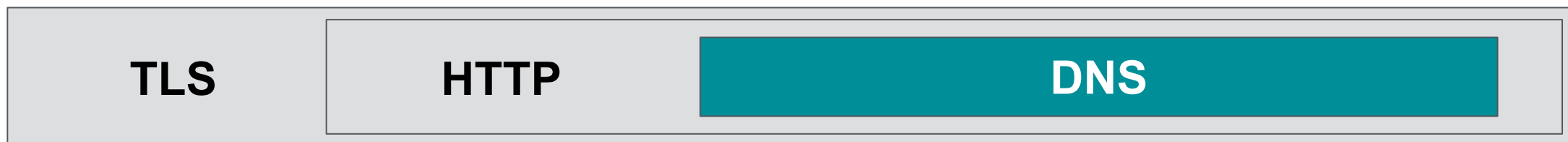
;; Received 468 B
;; Time 2018-03-31 15:20:57 PDT
;; From 1.1.1.1@853(TCP) in 12.6 ms
```

Source: <https://developers.cloudflare.com/1.1.1.1/dns-over-tls/>

DNS over HTTPS (DoH)

DNS over HTTPS

- Use TLS to encrypt the traffic
- Encapsulates DNS request/response by the HTTP
 - => HTTPS
- **Uses TCP transport port 443!**
 - The same port as for other HTTPS



DNS over HTTPS

- Defined in RFC 8484
- Brings encryption to DNS
- Can be enabled on the application level (browsers, proxies, tools)
- Currently supported in almost all browsers and mobile OS
- Hard to detect
 - Port based identification impossible
 - Employment of ML methods, blocklists, active scanning
- RFC recommended minimum HTTP/2
 - Adds additional establishment overhead

DoH POST Query

- Http accept type: "application/dns-message"
- Payload: DNS query in DNS Wireformat

```
:method = POST
:scheme = https
:authority = dnsserver.example.net
:path = /dns-query
accept = application/dns-message
content-type = application/dns-message
content-length = 33
```

```
<33 bytes represented by the following hex encoding>
00 00 01 00 00 01 00 00 00 00 00 00 03 77 77 77
07 65 78 61 6d 70 6c 65 03 63 6f 6d 00 00 01 00
01
```

DoH GET Query

- Http accept type: "application/dns-message"
- Query encoded using base64url without padding
 - Format: /dns-query?dns=<base64url_encoded>

```
:method = GET
:scheme = https
:authority = dnsserver.example.net
:path = /dns-query? (no space or Carriage Return (CR))
      dns=AAABAAABAAAAAAAAAAWE-NjJjaGFyYWN0ZXJsYWJl (no space or CR)
      bC1tYWtlcyliYXNlNjRlcmwtZGlzdGluY3QtZnJvbS1z (no space or CR)
      dGFuZGFyZC1iYXNlNjQhZXhhbXBsZQNjb20AAAEAAQ
accept = application/dns-message
```

DoH Query Response

- Standardised (RFC 8484)
- Http accept type: "application/dns-message"
- Success 2xx with query response
- Unsuccessful response 4xx without any query response

```
:status = 200
content-type = application/dns-message
content-length = 61
cache-control = max-age=3709
```

```
<61 bytes represented by the following hex encoding>
00 00 81 80 00 01 00 01 00 00 00 00 03 77 77 77
07 65 78 61 6d 70 6c 65 03 63 6f 6d 00 00 1c 00
01 c0 0c 00 1c 00 01 00 00 0e 7d 00 10 20 01 0d
b8 ab cd 00 12 00 01 00 02 00 03 00 04
```

DoH GET JSON

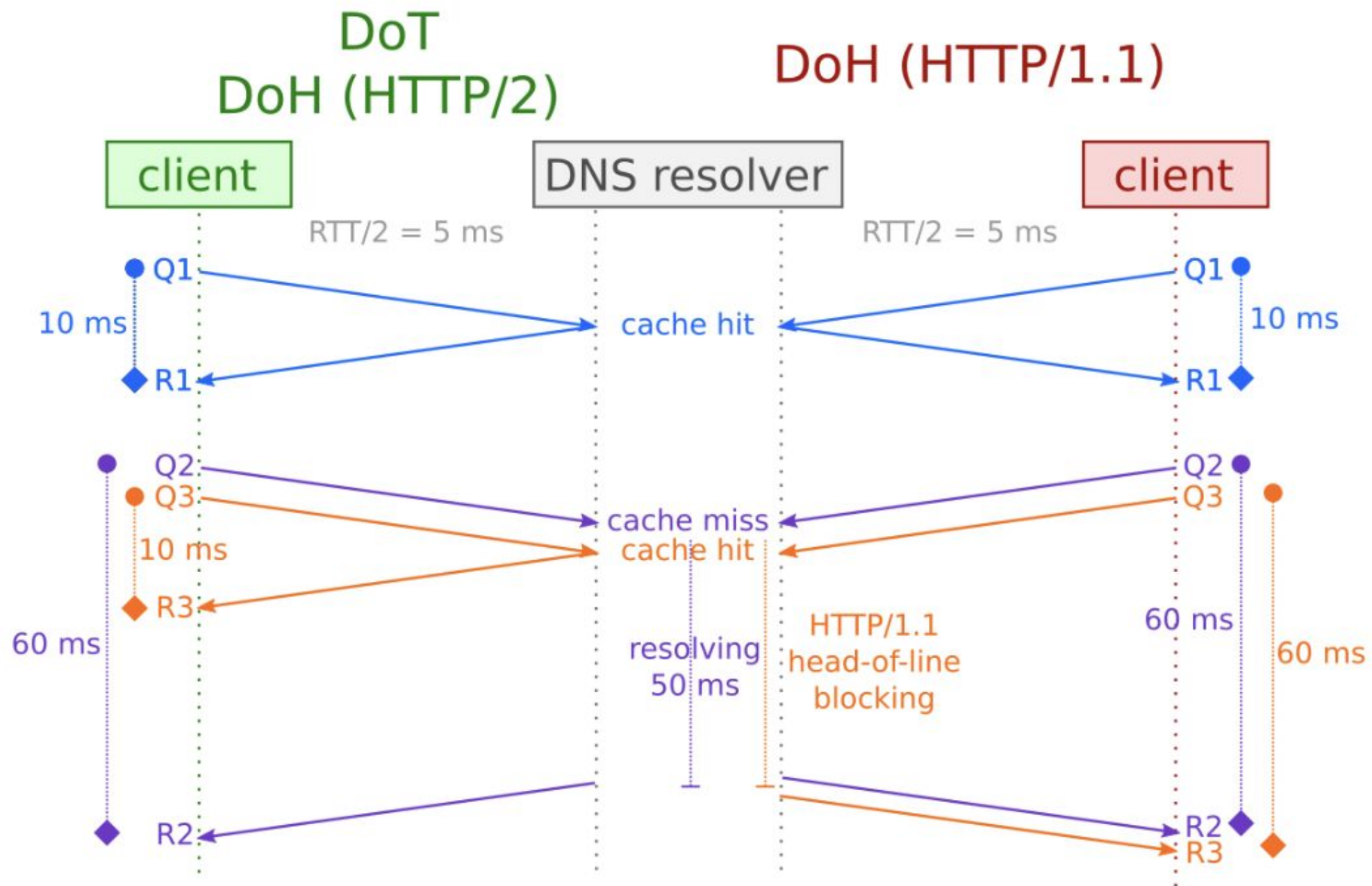
- **Not standardised**
- Cloudflare, Google - similar request, the same response
- Http accept type “application/dns-json”

```
curl -H 'accept: application/dns-json' 'https://cloudflare-dns.com/dns-query?name=example.com&type=AAAA'
```

```
{
  "Status": 0,
  "TC": false,
  "RD": true,
  "RA": true,
  "AD": true,
  "CD": false,
  "Question": [
    {
      "name": "example.com.",
      "type": 28
    }
  ],
  "Answer": [
    {
      "name": "example.com.",
      "type": 28,
      "TTL": 1726,
      "data": "2606:2800:220:1:248:1893:25c8:1946"
    }
  ]
}
```

Source: <https://developers.cloudflare.com/1.1.1.1/dns-over-https/json-format/>

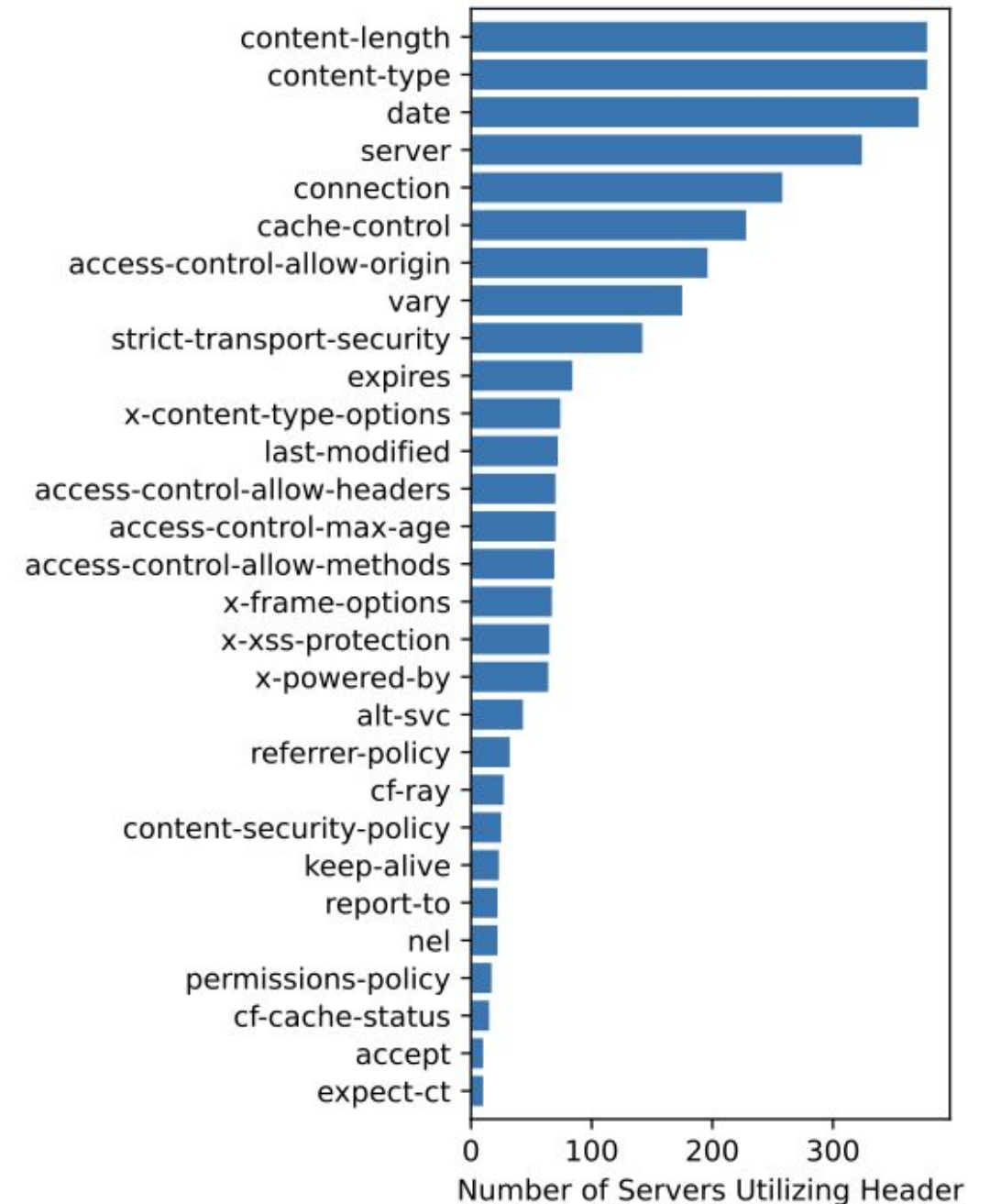
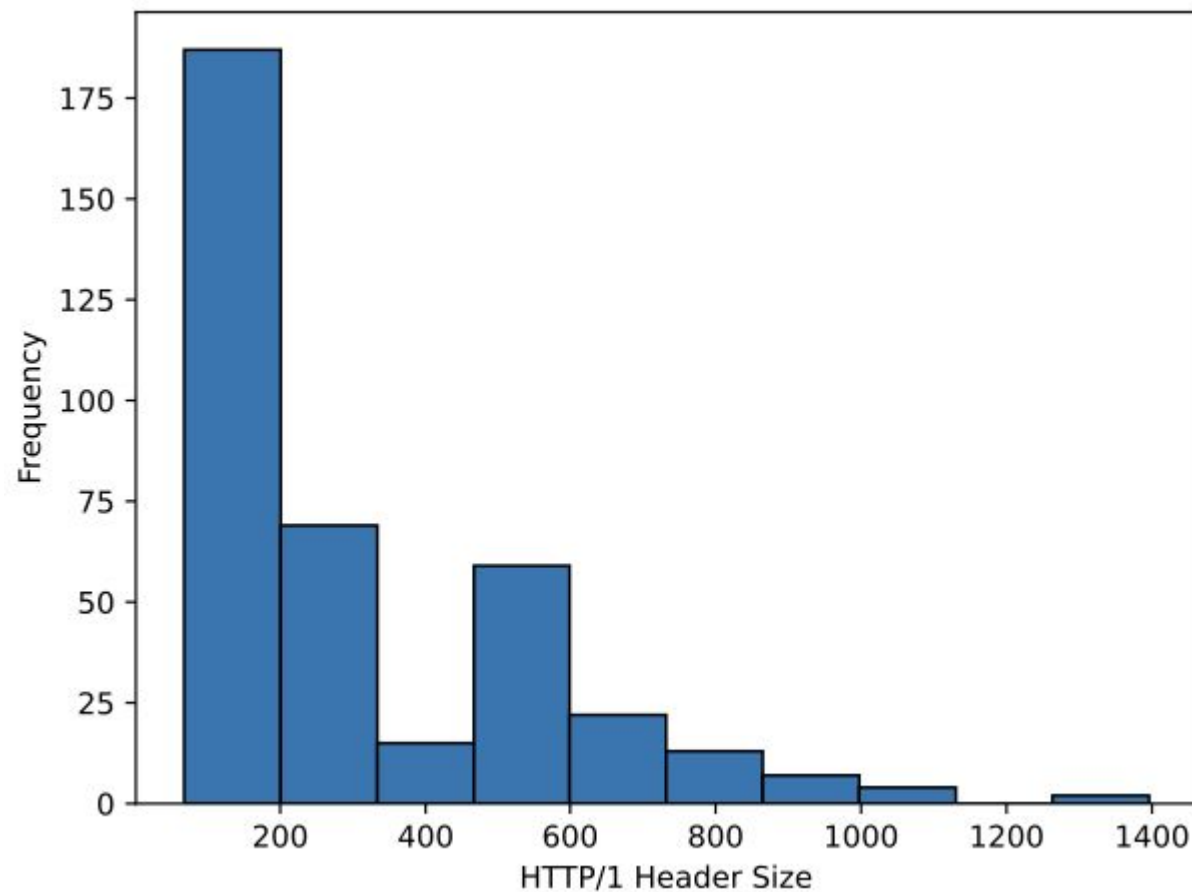
Why HTTP/2



Source: <https://en.blog.nic.cz/2020/11/25/encrypted-dns-in-knot-resolver-dot-and-doh/>

HTTP Headers

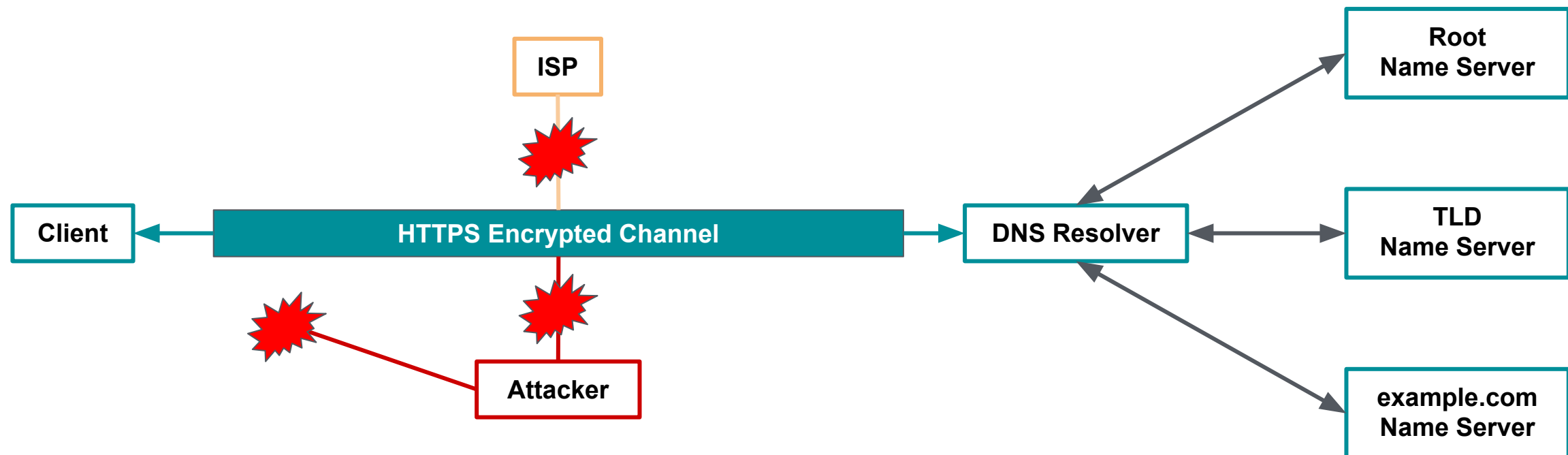
- Study of 431 publicly listed DoH resolvers



Source: <https://ieeexplore.ieee.org/abstract/document/10099347>

DNS over HTTPS

- DoH provides similar functionality as DoT
- DoH has higher payload overhead, longer initiation phase
- Does it solve any of the problems of DoT?

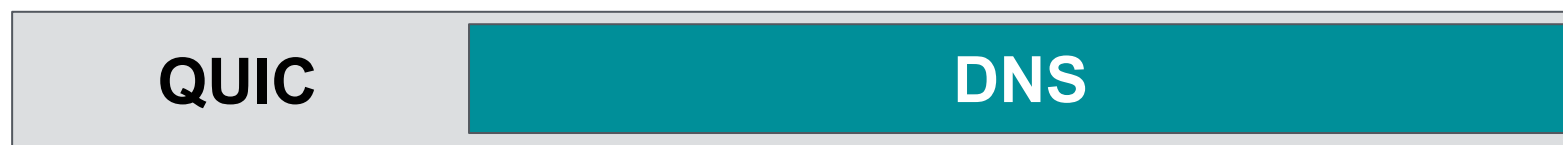


- Similar privacy concerns remain:
 - Can we trust the DNS Resolver provider? Is it really private?
 - Are those connections between DNS Resolver and Name Servers secure?

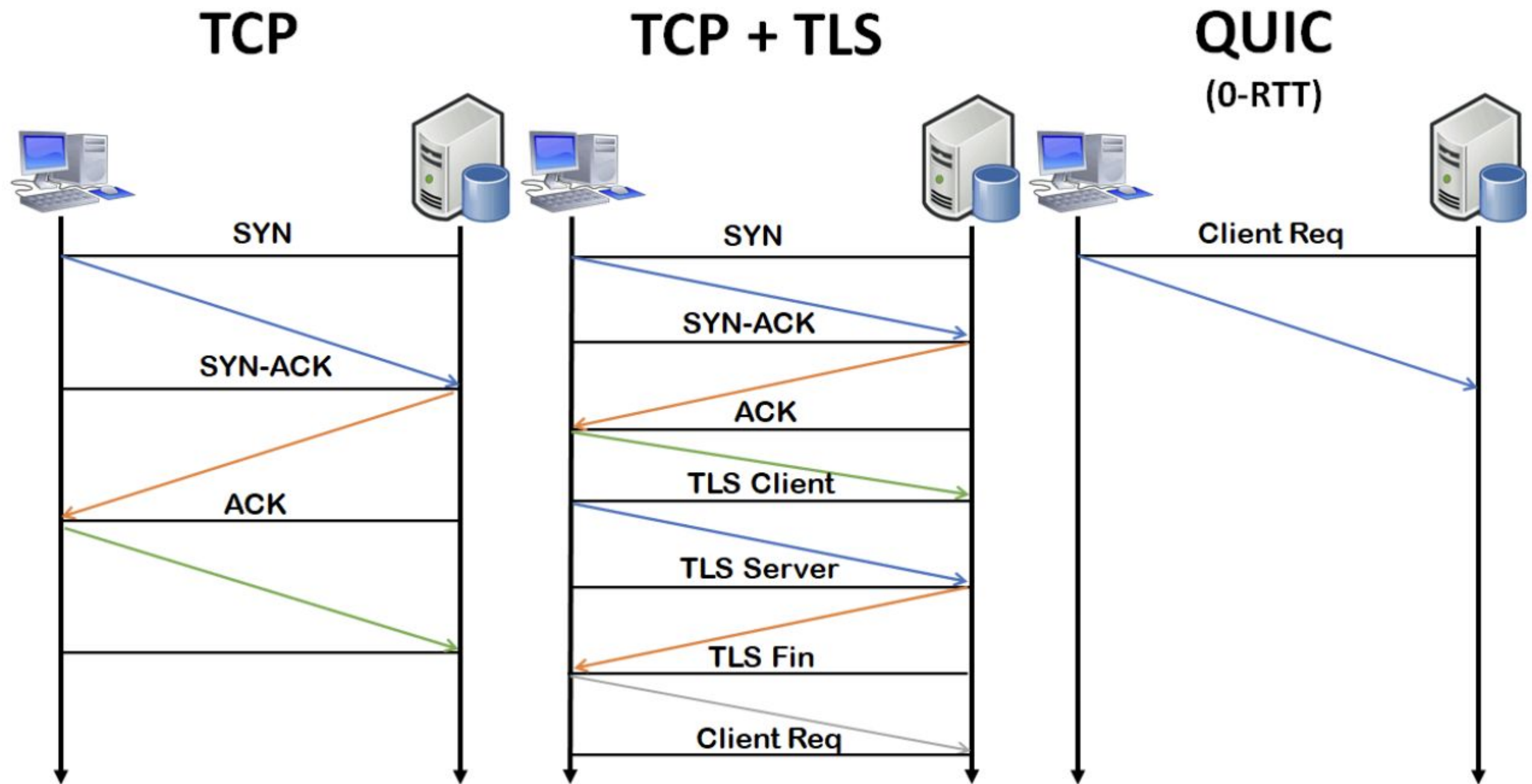
DNS Over QUIC (DoQ)

DNS over QUIC

- Defined in RFC 9250
- Use QUIC to transport DNS
- **Use dedicated port 853/udp**



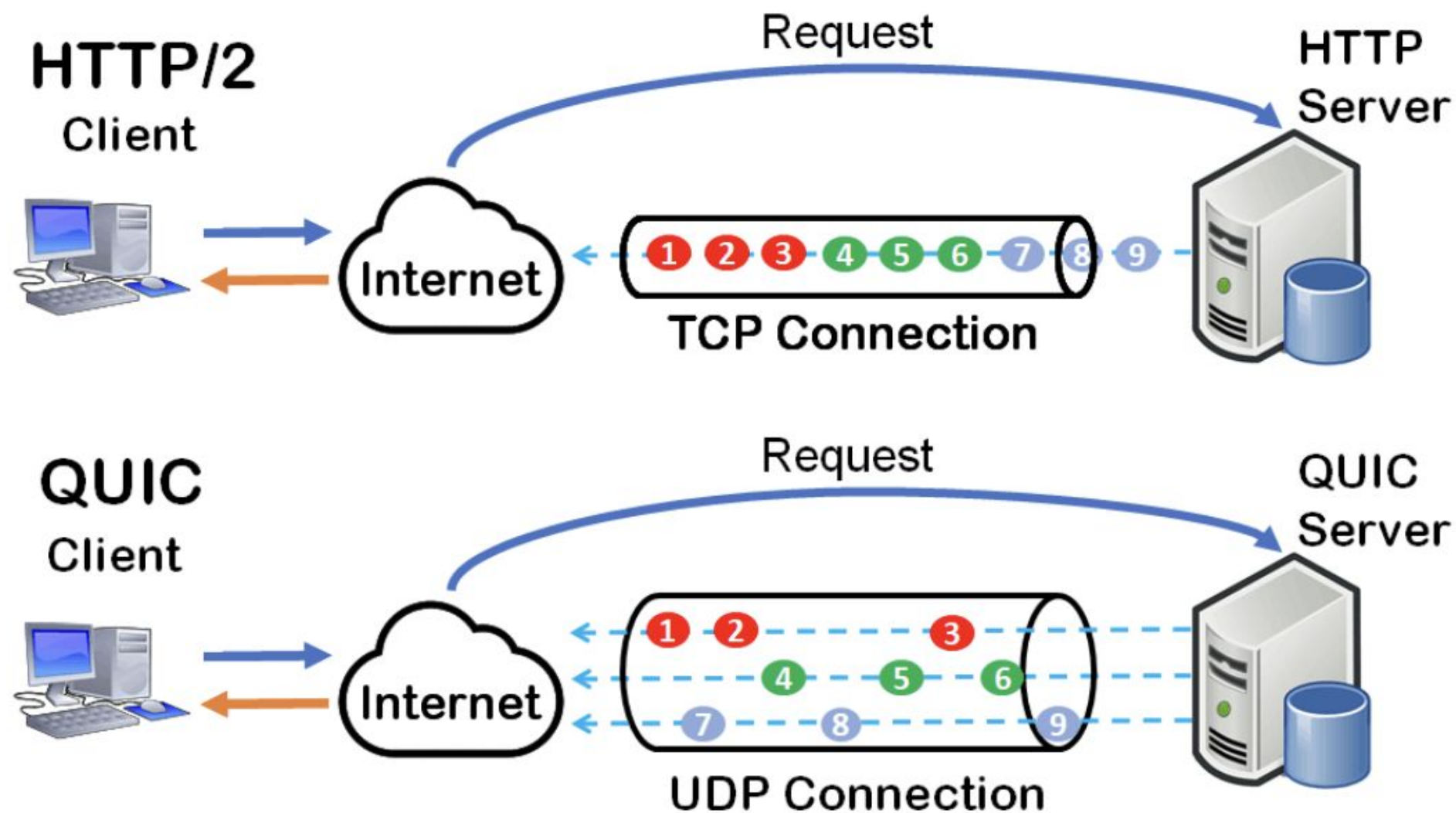
Why QUIC?



Source: <https://avenash-kumar.com/blog/quic-birth-of-new-protocol-in-layer4-family>

QUIC Better Than HTTP/2?

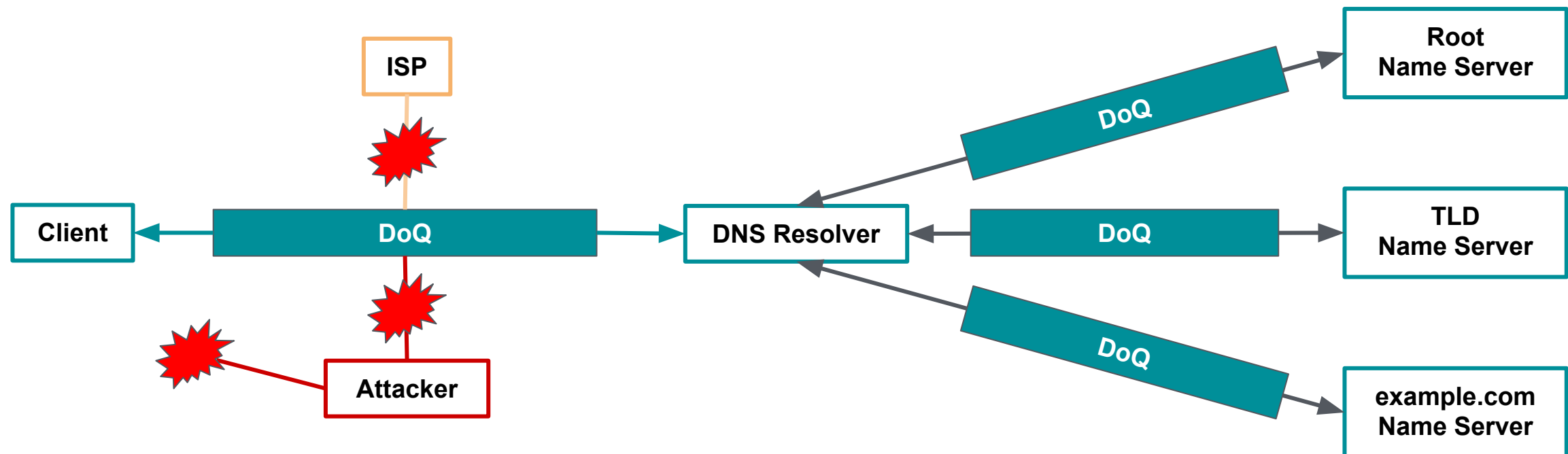
- Ahead-of-line blocking



Source: <https://avenash-kumar.com/blog/quic-birth-of-new-protocol-in-layer4-family>

DNS over QUIC

- DoQ provides similar functionality as DoT but even more
- DoQ has less payload overhead than DoH
- Does it solves any of the problems of previous mentioned?



- Similar privacy concerns remains:
 - Can we trust the DNS Resolver provider? Is it really private?
 - Are those connections between DNS Resolver and Name Servers secure?

Any Concerns?

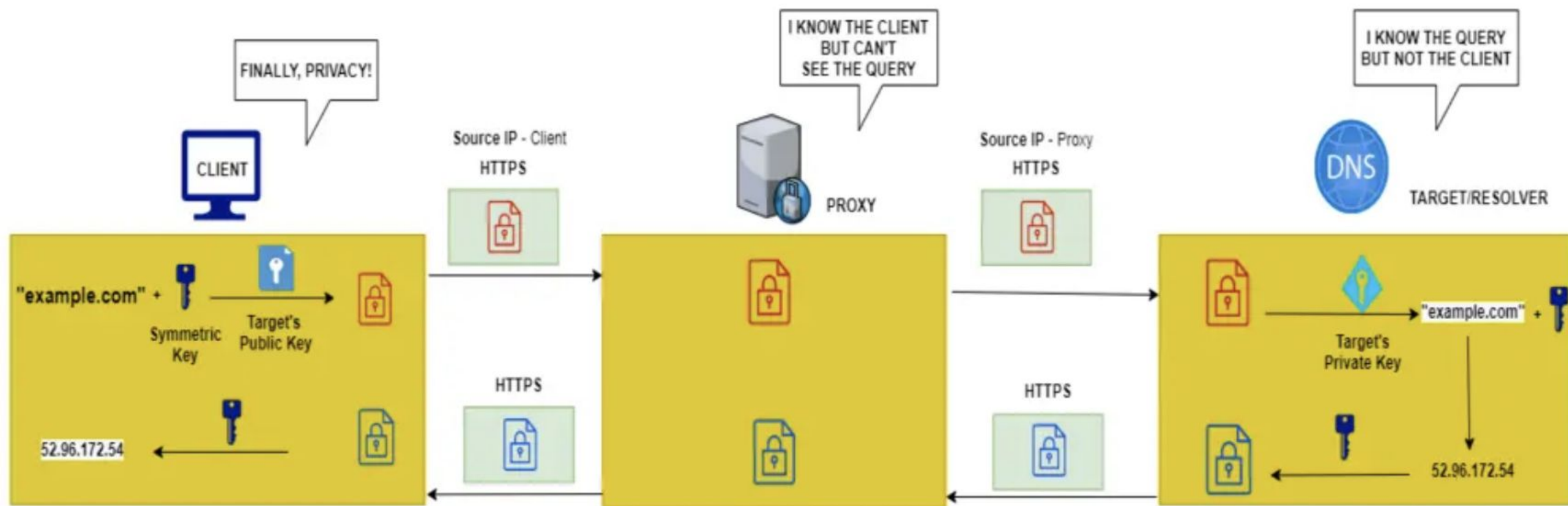
Any Concerns?

- Centralization
- User tracking
 - Sessions
 - DoH - HTTP Headers
- Does not prevent from all tracking
 - HTTPS SNI Extension
 - Unencrypted HTTP
 - Websites and application fingerprinting
- DoH bypass enterprise security policies, weakens security
- DoH used by various malware
- It is not VPN

Oblivious DNS Over HTTPS

Oblivious DNS Over HTTPS

- Defined in RFC 9230
- Trying to solve a privacy concern in DoH

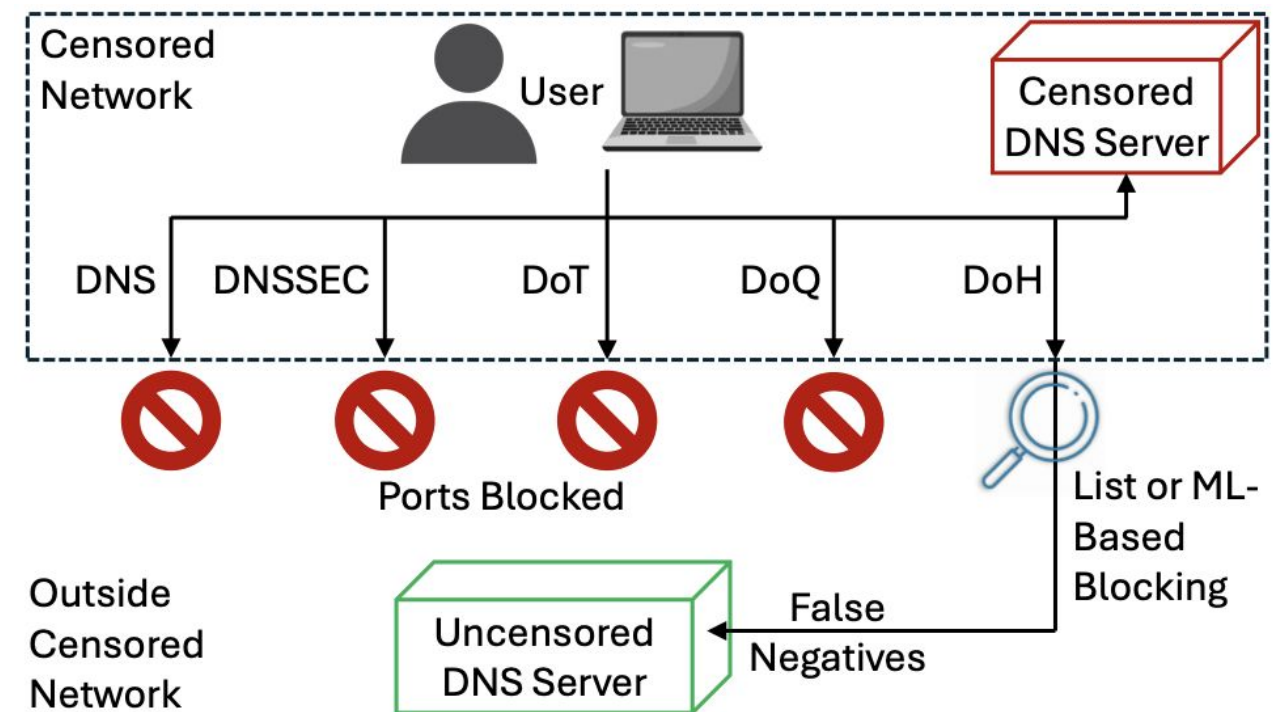


Source: <https://www.keysight.com/blogs/en/tech/nwvs/2021/03/11/oblivious-doh-enhanced-dns-privacy>

Detection and Detection Prevention

Detection and Detection Prevention

- Detection
 - Port based detection
 - DPI
 - Blocklists
 - Machine Learning
- Detection Prevention
 - Default port change
 - DoH default path change from “/dns-query”



URL Path	#	%
<i>dns-query</i>	328	86.77
/	22	5.8
other	28	7.4

Source: <https://arxiv.org/abs/2411.02805>, <https://ieeexplore.ieee.org/abstract/document/10099347>

Sources

- DNS
 - [RFC 1034](#), [RFC 1035](#), [RFC 2915](#), [RFC 3403](#), [RFC 3236](#),
[RFC 2782](#), [RFC 4408](#), [RFC 3596](#), [RFC 3833](#)
- DNSSEC
 - [RFC 4033](#), [RFC 4034](#), [RFC 4035](#), [RFC 5155](#)
- TLS
 - [RFC 5246](#)
- DNS over TLS
 - [RFC 7858](#), [RFC 8310](#)
- DNS over HTTPS
 - [RFC 8484](#)
- DNS over QUIC
 - [RFC 9250](#)
- Oblivious DNS over HTTPS
 - [RFC 9230](#)
- Other
 - [RFC 7918](#), [RFC 7413](#), [RFC 8446](#), [DoH story thesis](#)